COMQUENT
Industrial DevOps

WHITEPAPER

SBOM für CODESYS-Projekte V2.3, V3.5 und CODESYS 4

Software Bill of Materials nach Cyber Resilience Act und BSI TR-03183-2: was sich aus den drei CODESYS-Generationen auslesen lässt und wo Lücken bleiben



Abbildung 1: Steuerungstechnik an der Maschine: Laufzeit, Firmware, Bibliotheken und Anwenderprogramm gehören in die SBOM (KI-generierte Illustration).

Comquent GmbH
Industrial DevOps · CI/CD · DevSecOps · IT/OT-Konvergenz
Stand: Oktober 2026 · Bezug: CODESYS V2.3, CODESYS V3.5 und CODESYS 4

Inhalt

01 Einleitung
02 Auf einen Blick
03 Was in die SBOM einer CODESYS-Steuerung gehört
04 CODESYS V2.3: Bibliotheken mit Zeitstempel
05 CODESYS V3.5: Versionen nach der Auflösung
06 CODESYS 4: Textdateien und Lock-Datei
07 Die Unterschiede im Überblick
08 Lücken vermerken, nicht auffüllen
09 SBOM in der CI-Pipeline
10 Fazit
11 Ihr nächster Schritt mit Comquent
12 Glossar
13 Referenzen

Für wen dieses Whitepaper gedacht ist

Leiterinnen und Leiter der Steuerungstechnik, SPS-Programmierer sowie Produkt-Security- und Compliance-Verantwortliche im Maschinen- und Anlagenbau, die Steuerungen mit CODESYS oder einer darauf aufbauenden Hersteller-IDE projektieren und für ihre Maschinen eine SBOM nach dem Cyber Resilience Act aufbauen wollen. Besonders angesprochen sind Unternehmen, in deren Maschinenpark mehrere CODESYS-Generationen nebeneinander laufen.

1 Einleitung

Ab dem 11. Dezember 2027 braucht jede Maschine, die in der EU neu in Verkehr gebracht wird, eine Software Bill of Materials (SBOM). Der Cyber Resilience Act verlangt in Anhang I Teil II Nr. 1 eine SBOM in einem gängigen, maschinenlesbaren Format, die mindestens die obersten Abhängigkeiten des Produkts abdeckt [1]. Sie gehört zur technischen Dokumentation, muss nicht veröffentlicht werden und wird mindestens zehn Jahre aufbewahrt. Die Meldepflichten für aktiv ausgenutzte Schwachstellen gelten bereits seit dem 11. September 2026.

Für eine Maschine mit CODESYS-Steuerung ist die Frage, wie diese SBOM entsteht, schwieriger als für ein IT-Projekt. Es gibt keine Paketmanifeste, die ein Generator wie Syft oder cdxgen auswerten könnte, und keine CODESYS-Generation exportiert eine SBOM. Dazu kommt eine Eigenheit des Maschinenbaus: Steuerungen laufen fünfzehn oder zwanzig Jahre. In vielen Maschinenparks stehen deshalb mehrere CODESYS-Generationen nebeneinander, die Bestandsbaureihe auf CODESYS V2.3, die aktuelle auf V3.5. Seit September 2026 gibt es mit CODESYS 4 ein drittes Werkzeug [2].

Die drei Generationen speichern Projekte, Bibliotheken und Gerätebeschreibungen grundverschieden. Davon hängt ab, welche Angaben sich automatisch auslesen lassen, welche Lücken bleiben und wie viel Handarbeit jede Maschine kostet. Dieses Whitepaper geht die Generationen der Reihe nach durch, stellt sie nebeneinander und zeigt, wie die SBOM in jedem Build entsteht. Die Aussagen zu Projektformaten stützen sich auf die Handbücher und die Online-Hilfe von CODESYS sowie auf öffentlich verfügbare Exportdateien. Alle Quellen stehen im Referenzverzeichnis.

Eine Vorbemerkung: Eine SBOM allein erfüllt den CRA nicht. Sie ist ein Baustein der technischen Dokumentation. Ihren Nutzen entfaltet sie erst, wenn sie laufend gegen neue Sicherheitshinweise der Hersteller geprüft wird.

2 Auf einen Blick

Kernaussagen

- **Die SBOM ist Pflicht.** Ab dem 11. Dezember 2027 verlangt der CRA für jede neu in Verkehr gebrachte Maschine eine maschinenlesbare SBOM, auch für Steuerungen mit CODESYS.
- **Keine CODESYS-Generation exportiert eine SBOM.** Sie entsteht aus Projektexporten, Herstellerangaben und der Dokumentation des eigenen Codes.
- **V2.3 kennt keine Bibliotheksversionen.** Der Bibliotheksverwalter führt Dateiname und Zeitstempel. Belastbar wird die Angabe erst, wenn die Bibliotheksdatei im Repository liegt.
- **V3.5 löst Versionen erst beim Übersetzen auf.** Platzhalter und Verweise auf die neueste Version machen die SBOM vom Repository des Build-Rechners abhängig.
- **CODESYS 4 bringt eine Lock-Datei mit.** Sie nennt alle direkten und indirekten Bibliotheken mit exakter Version und Prüfsumme und ist die beste Quelle der drei Generationen.
- **Die Firmware steht in keinem Projekt.** Die Version einer Gerätebeschreibung ist nicht die Firmware des Geräts. Den Ist-Stand liefert die Inbetriebnahme.
- **Lücken gehören in die SBOM.** Was keine Quelle hergibt, wird vermerkt, nicht geschätzt. Nur so trägt der spätere Abgleich mit Sicherheitshinweisen.

3 Was in die SBOM einer CODESYS-Steuerung gehört

Der CRA definiert die SBOM als Aufstellung der Softwarebestandteile eines Produkts [1]. Hardware ist damit kein Pflichtinhalt. Sie liefert aber den Zusammenhang, ohne den eine SBOM für eine Maschine wenig taugt: zu welchem Gerät welche Firmware gehört, an welcher Steuerung welches Programm läuft. Für eine CODESYS-Station sind es fünf Arten von Bausteinen.

Baustein	Beispiel	Woher die Angabe kommt
Laufzeit und Firmware	CODESYS Control auf der Steuerung, Firmware eines Buskopplers	Steuerungs- bzw. Gerätehersteller; im Projekt steht meist nur ein Sollwert oder gar nichts
Bibliotheken	`standard.lib` (V2.3), `SM3_Basic, 4.5.1.0` (V3.5), Bibliotheken des Steuerungsherstellers	Bibliotheksverwaltung des Projekts
Anwenderprogramm	eigener Steuerungscode der Maschine	Quellen im Versionsverwaltungssystem, Version aus Release und Commit
Feldbusgeräte mit Firmware	CANopen-, PROFIBUS- oder EtherCAT-Teilnehmer	Steuerungskonfiguration; die Firmware steht fast nie im Projekt
Zugekaufte Software	geschützte Bibliotheken Dritter, Web-Anteile einer Visualisierung	Lieferant, Teil-SBOMs aus Syft oder cdxgen

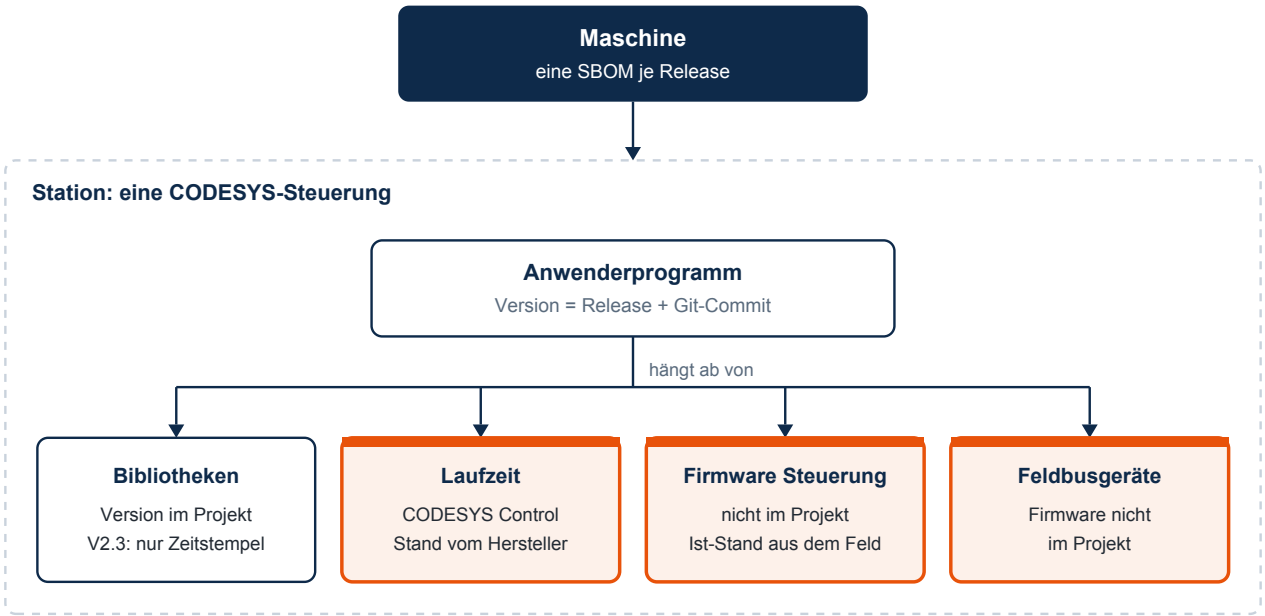


Abbildung 2: Aufbau einer CODESYS-Station in der SBOM. Orange markiert sind Bestandteile, die in keinem CODESYS-Projekt stehen; ihre Angaben kommen aus einer Hersteller-SBOM oder aus dem Feld.

3.1 Anforderungen der BSI TR-03183-2

Für Format und Pflichtfelder hat sich die Technische Richtlinie TR-03183-2 des BSI durchgesetzt, aktuell in Version 2.1.0 vom August 2025 [3]. Sie ist nicht bindend, wird aber in Ausschreibungen und Lieferverträgen verlangt. Sie fordert CycloneDX ab Version 1.6 oder SPDX ab Version 3.0.1 und je Komponente unter anderem Ersteller, Name, Version, Dateiname, Abhängigkeiten, Distributionslizenz und einen SHA-512-Hash der ausgelieferten Form. Schwachstellen gehören ausdrücklich nicht in die SBOM. Für CycloneDX hat das BSI die nötigen Felder in einer eigenen Property-Taxonomie festgelegt [4, 5].

3.2 Gerätebeschreibung ist nicht Firmware

Ein Punkt zieht sich durch alle drei CODESYS-Generationen, und er ist die häufigste Fehlerquelle bei selbst gebauten SBOMs: Die Version einer Gerätebeschreibung oder Zielsystemdatei ist nicht die Firmware-Version des Geräts. Ein öffentlich verfügbarer PLCopen-XML-Export eines CODESYS-V3.5-Projekts zeigt das gut [6]. Die Datei wurde mit CODESYS V3.5 SP15 geschrieben, die Steuerung trägt die Kennung `Version 3.5.15.0`. Die Zahl beschreibt die Gerätebeschreibung, die auf dem Engineering-Rechner installiert war. Welche Laufzeit oder Firmware auf der Steuerung im Feld läuft, sagt sie nicht.

Wer diese Version als Firmware in die SBOM schreibt, liefert eine Angabe, die jede Formatprüfung besteht und trotzdem falsch ist. Beim Abgleich mit Sicherheitshinweisen der Hersteller führt sie entweder zu falschen Treffern oder, schlimmer, zu übersehenen.

4 CODESYS V2.3: Bibliotheken mit Zeitstempel

Bei V2.3 lässt sich eine SBOM nur über einen Textexport aufbauen, und Bibliotheken haben keine Versionsnummer, sondern einen Dateizeitstempel. Wer heute noch Maschinen mit V2.3 ausliefert, braucht deshalb den längsten Vorlauf.

4.1 Stand der Linie

Die Linie endet mit Version 2.3.9.x; eine Version 2.5 gibt es nicht. CODESYS führt V2.3 einschließlich CODESYS Control V2.3 seit dem 1. Juli 2023 in der Servicephase und nennt V3 als Nachfolger [7]. Viele Hersteller-IDEs bauen auf V2.3 auf, etwa WAGO-I/O-PRO. Für Bestandsmaschinen, die in unveränderter Bauart weiter verkauft werden, gilt die SBOM-Pflicht trotzdem: Maßgeblich ist das Inverkehrbringen, nicht das Alter der Konstruktion.

4.2 Projekt und Zielsystem

Ein Projekt ist eine einzelne Datei `*.pro`, deren Format nicht öffentlich beschrieben ist. Neben den Bausteinen enthält sie die Ressourcen, darunter laut Handbuch den Bibliotheksverwalter, die Steuerungskonfiguration und die Zielsystemeinstellungen [8]. Die Steuerung wählt man über ein Target Support Package (TSP). Es besteht aus einer binären Zieldatei `*.trg`, einer Info-Datei `*.tnf` und weiteren Dateien wie Bibliotheken und Treibern. Das TSP beschreibt die Plattform, nicht den Firmware-Stand der Steuerung im Feld.

4.3 Bibliotheken

Bibliotheken sind Dateien `*.lib`, intern in CODESYS geschrieben oder extern in C implementiert, dann mit einer Header-Datei `*.h`. Der Bibliotheksverwalter führt jede Bibliothek mit Dateiname und „date and time of file“, im Handbuch etwa `standard.lib 30.3.99 11:30:14` [8]. Eine Versionsnummer wie in V3 gibt es nicht. Weicht der Zeitstempel der gefundenen Datei vom gespeicherten ab, markiert CODESYS den Eintrag mit `*`.

Für die SBOM ist der Zeitstempel damit die einzige Versionsangabe aus dem Projekt. Die TR-03183-2 lässt für Komponenten ohne Versionsnummer das Änderungsdatum als Version zu. Belastbar ist das aber nur, wenn die `.lib`-Datei selbst im Repository liegt und gehasht werden kann. Unsere Empfehlung: Legen Sie alle eingebundenen Bibliotheken mit dem Projekt ab. Das hilft nicht nur der SBOM, sondern auch jedem, der das Projekt in zehn Jahren noch einmal übersetzen muss.

4.4 Steuerungskonfiguration

E/A und Feldbusgeräte beruhen auf Konfigurationsdateien `*.cfg` und Gerätedateien wie `*.gsd` für PROFIBUS und `*.eds` für CANopen. Der Dialog eines PROFIBUS-Teilnehmers zeigt „HW Release and SW Release“ aus der GSD-Datei [8]. Das ist der Stand, den die Gerätedatei beschreibt, nicht die Firmware im Gerät.

4.5 Exportwege

Weg	Ergebnis	Bewertung für die SBOM
Projekt > Exportieren	ASCII-Datei `*.exp`, wahlweise eine Datei je Objekt. Exportierbar sind Bausteine, Datentypen, Visualisierungen und Ressourcen sowie die Einträge des Bibliotheksverwalters, „not the libraries themselves“.	Bevorzugter Weg: lesbar, versionierbar, ohne Reverse Engineering.
Batch-Modus	`codesys.exe /batch /cmd datei` mit den Befehlen `file open`, `project export` oder `project expmul`.	Erzeugt den Export ohne Oberfläche auf einem Windows-Agenten in der Pipeline.
PLCopen XML	Im Handbuch V2.3.9.24 nicht beschrieben.	Je Hersteller-IDE prüfen; nicht voraussetzen.
CODESYS V2.3 Converter	Überführt das Projekt nach V3.5; Gerät und Bibliotheken werden neu zugeordnet.	Beschreibt das umgewandelte Projekt, nicht die ausgelieferte V2.3-Maschine. Nur als Notlösung.

Offen ist, wie vollständig der `.exp`-Export Zielsystem und Steuerungskonfiguration wiedergibt. Das Handbuch nennt die Ressourcen als exportierbar, beschreibt das Format aber nicht. Das lässt sich nur an einem echten Projekt klären [8].

5 CODESYS V3.5: Versionen nach der Auflösung

V3.5 führt Bibliotheken mit Versionsnummer und Hersteller, und ein PLCopen-XML-Export liefert Gerät und Bibliotheken in lesbarer Form. Die Schwierigkeit liegt woanders: Welche Bibliotheksversion tatsächlich in die Steuerung geladen wird, entscheidet sich erst auf dem Rechner, auf dem übersetzt wird.

5.1 Projekt und Geräte

Das Projekt ist eine binäre Datei `*.project`. Sie enthält einen Gerätebaum mit der Steuerung, ihren Applikationen und den Feldbusgeräten. Jedes Gerät verweist auf eine Gerätebeschreibung `*.devdesc.xml`, die im Geräte-Repository des Rechners installiert sein muss. Die Kennung im Projekt besteht aus Typ, Id und Version; die Version gehört zur Gerätebeschreibung.

5.2 Bibliotheken und Platzhalter

Bibliotheken liegen als `*.library` oder `*.compiled-library` in einem oder mehreren Bibliotheks-Repositories. Im Projekt stehen sie auf zwei Arten. Ein fester Verweis nennt Name, Version und Hersteller, im öffentlichen Beispielexport etwa `Robin, 0.1.2 (INESC TEC)` [6]. Ein Platzhalter wie `#SM3_Basic` nennt dagegen nur eine Standardauflösung, hier `SM3_Basic, 4.5.1.0 (3S - Smart Software Solutions GmbH)`. Welche Bibliothek tatsächlich dahintersteht, legen die Gerätebeschreibung oder der Platzhalter-Dialog fest.

Die Online-Hilfe nennt das Ergebnis „Effective version“ und stellt klar: „This version of the library is used in the application“ [9]. Für die SBOM folgt daraus eine einfache Regel. Die Version im Verweis ist ein Wunsch, die effektive Version ist die Wahrheit. Eine SBOM, die nur den Verweis liest, kann von der geladenen Software abweichen, sobald zwei Rechner unterschiedliche Repositories haben. Ist ein Verweis auf die jeweils neueste Version gesetzt, hängt das Ergebnis sogar davon ab, wann zuletzt jemand ein Bibliothekspaket installiert hat.

5.3 Exportwege

Weg	Ergebnis	Bewertung für die SBOM
Projekt > Exportieren	CODESYS-XML `*.export`, laut Hilfe „fully compatible with the CODESYS project format“ [10].	Vollständig, aber ein internes Format.
Projekt > PLCopen XML exportieren	Austauschformat; nur eine Teilmenge, „100% compatibility cannot be guaranteed“ [10]. Enthält im Bereich `addData` Gerätekennung und Bibliotheksverweise, im Kopf die CODESYS-Version [6].	Einfacher Einstieg: eingecheckt und auf jedem Agenten ohne CODESYS lesbar. Zeigt die Standardauflösung, nicht die effektive.
Scripting	CODESYS ohne Oberfläche (`--noUI --runscript`) liest Gerätekennung und Bibliotheksverweise einschließlich der effektiven Auflösung [11].	Genauester Weg; braucht Windows, eine CODESYS-Installation und die passenden Repositories auf dem Build-Agenten.

In der Praxis empfehlen wir einen Zwischenschritt: Ersetzen Sie Verweise auf die neueste Version durch feste Versionen und halten Sie die Bibliotheks-Repositories der Build-Agenten im selben Stand wie die Arbeitsplätze. Dann stimmen Standard- und effektive Auflösung überein, und der PLCopen-Export reicht für eine belastbare SBOM.

6 CODESYS 4: Textdateien und Lock-Datei

CODESYS 4 bringt die für eine SBOM günstigste Projektablage mit: lesbare Textdateien und eine Lock-Datei, die jede aufgelöste Bibliothek mit exakter Version und Prüfsumme festhält. Version 1.0.0.0 ist seit dem 24. September 2026 verfügbar [2]. CODESYS stellt sie als zweites Werkzeug neben V3.5, nicht als Ersatz.

6.1 Projektablage

Ein Projekt ist ein Verzeichnis mit UTF-8-Textdateien, eine Datei je Objekt. IEC-Quelltext liegt als Text vor, strukturierte Daten als JSON, Gerätebeschreibungen als XML [12]. Die Geräte stehen in `DeviceTree.json`. Ein zentrales Geräte-Repository gibt es nicht; die Beschreibungen kommen aus Erweiterungen und einem Cache im Projekt [13]. Das Verzeichnis lässt sich ohne Umweg mit Git versionieren.

6.2 Bibliotheken und Lock-Datei

`Libraries.json` beschreibt die gewünschten Bibliotheksverweise. `Libraries.lock.json` „records the specific resolution of all direct and indirect dependencies“, mit exakter Version und SHA384-Prüfsumme [12]. Aufgelöst wird nur, wenn der Anwender es auslöst; die Repositories stehen in `LibraryRepositories.prefs.json` [13].

Für die SBOM ist die Lock-Datei die beste Quelle aller drei Generationen. Sie nennt auch indirekte Abhängigkeiten, die in V3.5 nur über Scripting sichtbar werden, und der Build-Agent löst dieselben Versionen auf wie der Arbeitsplatz. Das Problem aus Abschnitt 5.2 entfällt.

6.3 Verhältnis zu V3.5

CODESYS 4 nutzt dieselbe Laufzeit wie CODESYS 3; übersetzte Bibliotheken sind in beide Richtungen austauschbar. Auf der Steuerung ist mindestens CODESYS V3.5 SP16 nötig [12]. V3.5-Projekte lassen sich nicht direkt öffnen. Die erste Version zielt vor allem auf Bibliotheksentwicklung; Visualisierung, Motion und Safety bleiben vorerst in V3.5 [2]. Eine Scripting-Schnittstelle wie in V3.5 gibt es nicht. An ihre Stelle treten der direkte Dateizugriff und die Kommandozeile `c4-cli` [13].

6.4 Zwei Einschränkungen

– Das Dateiformat ist nicht als Schnittstelle spezifiziert, und CODESYS plant etwa alle zwei Monate eine neue Version [12]. Ein Leser muss deshalb die CODESYS-4-Version jeder Quelle prüfen und unbekannte Versionen melden, statt still falsch zu lesen.
– SHA384 ist nicht der Hash, den die TR-03183-2 verlangt. Er belegt die Identität der Bibliothek und kann zusätzlich in die SBOM; den SHA-512 der ausgelieferten Form ersetzt er nicht.

7 Die Unterschiede im Überblick

Von V2.3 über V3.5 zu CODESYS 4 wird die Bibliotheksangabe genauer und die Projektablage offener. Die Firmware der Geräte steht in keiner Generation im Projekt.

Merkmal	CODESYS V2.3	CODESYS V3.5	CODESYS 4
Status (Oktober 2026)	Servicephase seit 01.07.2023	aktuelle Hauptlinie	Version 1.0.0.0 seit 24.09.2026
Projektablage	eine Datei `*.pro`, Format nicht offen	eine Binärdatei `*.project`	Verzeichnis mit Text- und JSON-Dateien
Lesbarer Export	ASCII-Export `*.exp`	CODESYS-XML `*.export`, PLCopen XML	nicht nötig, Ablage selbst ist lesbar
Steuerung	Zielsystem aus TSP (`*.trg`, `*.tnf`)	Gerätebeschreibung `*.devdesc.xml` mit Typ, Id, Version	`DeviceTree.json`, Beschreibung im Projekt-Cache
Bibliotheksversion	Zeitstempel der `*.lib`	Version und Hersteller, Platzhalter, effektive Version	exakte Version und SHA384 in `Libraries.lock.json`
Indirekte Bibliotheken	nicht ausgewiesen	nur über Scripting oder Bibliotheksverwalter	in der Lock-Datei
Feldbusgeräte	`*.cfg`, GSD, EDS	Gerätebeschreibungen im Gerätebaum	Gerätebeschreibungen im Projekt
Firmware im Projekt	nein	nein	nein
Automatischer Export	`/batch /cmd` (Windows)	Scripting `--noUI` (Windows)	`c4-cli`, direkter Dateizugriff
Lesen ohne CODESYS auf dem Agenten	ja, aus eingechecktem `.exp`	ja, aus eingechecktem PLCopen XML	ja, direkt aus dem Repository
Größte Lücke für die SBOM	keine Versionsnummern	Auflösung hängt vom Repository des Rechners ab	Format kann sich mit jeder Version ändern

8 Lücken vermerken, nicht auffüllen

Eine SBOM aus CODESYS-Projekten hat Lücken. Das ist kein Fehler, solange sie benannt sind. Ein Fehler wäre, sie mit plausiblen Werten zu füllen: eine Firmware aus dem Typnamen geraten, die Version der Gerätebeschreibung als Firmware ausgegeben, ein Platzhalter-Hash, damit der Validator Ruhe gibt. Solche Werte bestehen jede Formatprüfung. Beim Abgleich mit Sicherheitshinweisen erzeugen sie falsche Treffer oder verdecken echte.

CycloneDX bietet für ehrliche Lücken zwei Mittel: Properties an der betroffenen Komponente und den Abschnitt `compositions`, der die Vollständigkeit als `incomplete` oder `unknown` kennzeichnet [5]. Die typischen Lücken bei CODESYS-Projekten:

Lücke	Betrifft	Was sie schließt
Firmware nicht im Projekt	alle Generationen, alle Geräte	Ist-Stand aus Inbetriebnahme oder Service, als Datei eingelesen
Bibliotheksversion nur als Zeitstempel	V2.3	`.lib`-Datei im Repository ablegen und hashen
Bibliotheksversion nicht aufgelöst (neueste Version, Platzhalter)	V3.5	feste Versionen im Projekt oder effektive Auflösung per Scripting
Kein SHA-512 der ausgelieferten Form	Hersteller-Firmware, Laufzeit	nach TR-03183-2 zulässig, wenn die Art der Zusammensetzung keinen Hash erlaubt; als Hinweis vermerken
Keine Hersteller-SBOM	Laufzeit und Firmware des Steuerungsherstellers	Hersteller-SBOM anfordern und einbinden, sobald verfügbar
Distributionslizenz unbekannt	Bibliotheken Dritter	Lizenz beim Lieferanten klären und in der Konfiguration erklären

Was Sie selbst ergänzen, etwa eine Lizenz oder einen Hersteller, ist eine eigene Quelle und wird in der SBOM als „deklariert“ gekennzeichnet. So bleibt erkennbar, welcher Wert aus dem Projekt stammt und welcher aus einer Erklärung. Prüfer und Kunden fragen genau danach.

9 SBOM in der CI-Pipeline

Die SBOM entsteht am besten in jedem Build, aus denselben Quellen wie die Software und gebunden an den Git-Commit. Dann gehört zu jedem Release genau eine SBOM, und sie lässt sich nach Jahren noch einem Stand zuordnen. Eine SBOM, die einmal im Jahr von Hand entsteht, ist am Tag nach der nächsten Änderung veraltet.



Abbildung 3: Ablauf in der Pipeline für Maschinen mit mehreren CODESYS-Generationen. Das Prüf-Gate unterscheidet Entwicklungs- und Release-Build.

- **Quelle bereitstellen.** V2.3: `.exp`-Export einchecken oder im Batch-Modus auf einem Windows-Agenten erzeugen. V3.5: PLCopen-XML-Export einchecken oder per Scripting erzeugen. CODESYS 4: Projektverzeichnis und `Libraries.lock.json` liegen bereits im Repository.
- **Je Station auslesen.** Steuerung, Feldbusgeräte, Bibliotheken und Werkzeugversion in ein gemeinsames Modell übernehmen. Die Version der Gerätebeschreibung bleibt als Eigenschaft erhalten, nicht als Firmware.
- **Zusammenführen.** Stationen unter der Maschine einordnen, Hersteller-SBOMs und Teil-SBOMs zuordnen, das Anwenderprogramm mit Release, Commit und SHA-512 über die Quellen ergänzen.
- **Prüfen.** Schema CycloneDX 1.6 und Pflichtfelder der TR-03183-2. Im Entwicklungs-Build sind vermerkte Lücken Warnungen, im Release-Build brechen sie den Build ab.
- **Ablegen.** SBOM, Prüfbericht und Ergebnis archivieren und optional an Dependency-Track übergeben, das die SBOM laufend gegen neue Schwachstellendaten prüft.

Die Ausgabe muss reproduzierbar sein: gleiche Eingabe, gleiche Datei, Byte für Byte. Dazu gehören eine feste Sortierung, stabile Kennungen je Komponente und ein Zeitstempel aus dem Commit statt aus der Uhr des Agenten. Wie eine solche Pipeline mit Jenkins im Detail aussieht, beschreibt unser Whitepaper zu TIA Portal V21 [14]; der Ablauf lässt sich auf CODESYS übertragen.

10 Fazit

Für alle drei CODESYS-Generationen lässt sich eine SBOM automatisch und ohne erfundene Werte erzeugen. Der Aufwand fällt nur an verschiedenen Stellen an. V2.3 braucht einen Textexport und die `.lib`-Dateien im Repository, sonst bleibt von jeder Bibliothek nur ein Zeitstempel. V3.5 liefert Versionen, aber erst feste Verweise oder die effektive Auflösung machen die SBOM unabhängig vom Build-Rechner. CODESYS 4 hat mit der Lock-Datei die beste Grundlage und verlangt dafür einen Leser, der mit jeder neuen Version Schritt hält.

In keiner Generation steht die Firmware der Geräte im Projekt. Der projektierte Stand ist die halbe Antwort, den Ist-Stand liefert die Inbetriebnahme. Wer beides abgleicht, findet Abweichungen, bevor ein Sicherheitshinweis sie aufdeckt. Bis zum 11. Dezember 2027 bleibt gut ein Jahr. Fangen Sie bei den V2.3-Maschinen an, die weiter ausgeliefert werden: Dort müssen Exporte und Bibliotheksdateien erst zusammengetragen werden.

11 Ihr nächster Schritt mit Comquent

Comquent begleitet seit 2006 Unternehmen aus Fertigung, Automotive und Automatisierungstechnik bei CI/CD, DevSecOps und Industrial DevOps. Bei der SBOM für Ihre CODESYS-Maschinen unterstützen wir Sie in jeder Phase:

Leistung	Was Sie erhalten
SBOM-Readiness-Check	Bestandsaufnahme Ihrer Maschinentypen, CODESYS-Generationen, Exporte und Lieferanten; Ergebnis ist ein SBOM-Konzept mit Fahrplan bis Dezember 2027.
Pilot-SBOM	Eine vollständige CycloneDX-SBOM für eine Ihrer Maschinen, mit Lückenliste und dem Weg, jede Lücke zu schließen.
PLC SBOM Builder in Ihrer Pipeline	Unser Kommandozeilenwerkzeug erzeugt und prüft die SBOM in Jenkins, GitLab CI oder Azure DevOps, auch für Maschinen mit Steuerungen mehrerer Hersteller.
Schwachstellenüberwachung	Aufbau von Dependency-Track und CSAF-Import für Ihre Maschinen im Feld.
Schulung über die Comquent Academy	SBOM und CRA für Automatisierungsteams, praxisnah in einer eigenen Cloud-Schulungsumgebung.

Der **PLC SBOM Builder** [15] liest CODESYS-Projekte neben TIA Portal, Studio 5000 und TwinCAT, führt alles zu einer SBOM je Maschine zusammen, prüft die Pflichtfelder der TR-03183-2 als Build-Gate und schreibt einen lesbaren Prüfbericht mit allen Lücken. Der Adapter für CODESYS V3.5 entsteht zuerst; V2.3 und CODESYS 4 folgen nach einer Prüfung an echten Projekten. Dafür suchen wir Pilotkunden, besonders mit Bestandsprojekten auf V2.3 und ersten Projekten auf CODESYS 4.

Sprechen Sie mit uns über Ihre SBOM

In einem Erstgespräch klären wir, welche CODESYS-Generationen in Ihren Maschinen laufen, welche Exporte es schon gibt und welcher Pilotumfang sinnvoll ist.

Comquent GmbH · Lindberghstr. 7 · 82178 Puchheim

Telefon +49 89 9393 3840 · info@comquent.de

comquent.de/produkte/plc-sbom-builder · comquent.academy

12 Glossar

Begriff	Erklärung
`c4-cli`	Kommandozeile von CODESYS 4; übersetzt Projekte ohne Oberfläche.
CODESYS Control	Laufzeitsystem von CODESYS auf der Steuerung.
CPE	Common Platform Enumeration, Kennung für Produkte in Schwachstellendatenbanken.
CRA	Cyber Resilience Act, Verordnung (EU) 2024/2847 über Cybersicherheitsanforderungen an Produkte mit digitalen Elementen.
CSAF	Common Security Advisory Framework, maschinenlesbares Format für Sicherheitshinweise von Herstellern.
CycloneDX	SBOM-Format der OWASP Foundation, hier in Version 1.6 als JSON.
Effektive Version	In V3.5 die Bibliotheksversion, die nach Auflösung aller Platzhalter tatsächlich in die Applikation geladen wird.
EDS, GSD, GSDML	Gerätebeschreibungsdateien für CANopen, PROFIBUS und PROFINET.
Gerätebeschreibung	Datei, mit der die Engineering-Umgebung ein Gerät kennt (`*.devdesc.xml` in V3.5); ihre Version ist nicht die Firmware.
Ist-Stand	Im Feld ausgelesener Stand, etwa bei Inbetriebnahme oder Service.
Lock-Datei	In CODESYS 4 `Libraries.lock.json` mit allen aufgelösten Bibliotheken, Versionen und Prüfsummen.
Lücke	Pflichtangabe, die keine Quelle liefert; wird in der SBOM vermerkt, nicht aufgefüllt.
Platzhalter	In V3.5 ein Bibliotheksverweis, dessen Ziel erst die Gerätebeschreibung oder der Anwender festlegt.
PLCopen XML	Herstellerneutrales XML-Austauschformat für IEC-61131-3-Projekte.
SBOM	Software Bill of Materials, Stückliste der Softwarebestandteile eines Produkts.
Soll-Stand	Im Engineering-Projekt projektierter Stand.
Station	Eine Steuerung mit allem, was an ihr hängt.
TR-03183-2	Technische Richtlinie des BSI zu SBOM-Format und Pflichtfeldern, aktuell Version 2.1.0.
TSP	Target Support Package; beschreibt in V2.3 das Zielsystem.

13 Referenzen

Abrufdatum aller Online-Quellen: 31.10.2026, soweit nicht anders angegeben.

[1] Europäische Union: Verordnung (EU) 2024/2847 (Cyber Resilience Act), Amtsblatt der EU, insbesondere Art. 3 Nr. 39, Art. 13 Abs. 13 und Anhang I Teil II Nr. 1. https://eur-lex.europa.eu/eli/reg/2024/2847/oj

[2] CODESYS Group: „CODESYS 4 Version 1.0.0.0 is available“, Meldung, September 2026. Abgerufen 31.10.2026 im Rahmen der Comquent-Recherche; bei der Schlussprüfung für automatisierte Abrufe gesperrt. https://www.codesys.com/company/news-center/latest-news/codesys-4-version-1000-is-available/

[3] BSI: Technische Richtlinie TR-03183-2, Cyber Resilience Requirements for Manufacturers and Products, Part 2: Software Bill of Materials (SBOM), Version 2.1.0, 20.08.2025. https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TR03183/BSI-TR-03183-2_v2_1_0.pdf

[4] BSI: TR-03183 CycloneDX Property Taxonomy, GitHub. https://github.com/BSI-Bund/tr-03183-cyclonedx-property-taxonomy

[5] OWASP Foundation: CycloneDX v1.6 JSON Reference. https://cyclonedx.org/docs/1.6/json/

[6] INESC TEC: Projekt „robin“, PLCopen-XML-Export eines CODESYS-V3.5-SP15-Projekts (robin_updater/cfg/codesys_project.xml), Apache-2.0, Commit 42ba562. https://github.com/ScalABLE40/robin

[7] CODESYS Group: CODESYS-Produkte in der Servicephase und abgekündigte Produkte, Eintrag „CODESYS V2.3, incl. CODESYS Control V2.3“. Angabe laut Suchindex; die Seite war am 31.10.2026 für automatisierte Abrufe gesperrt. https://de.codesys.com/ecosystem/up-to-date/release-lifecycle/abkuendigungen/

[8] 3S-Smart Software Solutions GmbH: User Manual for PLC Programming with CoDeSys 2.3, Dokumentversion 6.0, CoDeSys V2.3.9.24, Stand 28.10.2010. Kapitel 2.1 (Project Components), 4.3 (Project Export), 6.4 (Library Manager), 6.6 (PLC Configuration), 6.12 (Target Settings), Anhang F (Command Line). https://www.ee.pw.edu.pl/~purap/PLC/manuals/m07590333_00000000_1en.pdf

[9] CODESYS GmbH: Online-Hilfe CODESYS Development System, „Object: Library Manager“. https://content.helpme-codesys.com/en/CODESYS%20Development%20System/_cds_obj_library_manager.html

[10] CODESYS GmbH: Online-Hilfe CODESYS Development System, „Exporting and Importing Projects“. https://content.helpme-codesys.com/en/CODESYS%20Development%20System/_cds_project_export_import.html

[11] CODESYS GmbH: Online-Hilfe CODESYS Scripting Engine. https://content.helpme-codesys.com/en/ScriptingEngine/

[12] CODESYS GmbH: Online-Hilfe CODESYS 4, Startseite. https://content.helpme-codesys.com/en/CODESYS%204/_c4_start_page.html

[13] CODESYS GmbH: Online-Hilfe CODESYS 4, „Switching from CODESYS 3“. https://content.helpme-codesys.com/en/CODESYS%204/_c4_start_page-2083130.html

[14] Comquent GmbH: Whitepaper „SBOM für SPS-Projekte mit TIA Portal V21“, Oktober 2026. https://comquent.de/ressourcen/whitepapers

[15] Comquent GmbH: PLC SBOM Builder, Produktseite. https://comquent.de/produkte/plc-sbom-builder

CODESYS ist eine Marke der CODESYS GmbH. WAGO-I/O-PRO ist eine Marke der WAGO GmbH & Co. KG. CycloneDX ist ein Projekt der OWASP Foundation, SPDX ein Projekt der Linux Foundation. Alle weiteren genannten Marken sind Eigentum der jeweiligen Inhaber. Stand der Angaben: 31. Oktober 2026. Die Angaben entsprechen dem Stand der genannten Quellen und stellen keine Rechtsberatung dar; Produktfunktionen und regulatorische Vorgaben können sich ändern.